ChatGPT

Internet Search v2 — итоговое техническое задание

Executive summary

Подготовлено итоговое **developer-ready ТЗ для передачи команде разработки/CodeX**. Документ сформирован как PDF на **31 страницу**, содержит архитектуру, схемы БД, API-контракт, UI-flows, алгоритмы модулей, формат шаблонов, GlobalProtect rules, observability, CI/CD, Docker deployment, performance/benchmark plan, milestones и формальный acceptance checklist.

Скачать итоговое ТЗ в PDF

Скачать редактируемый Markdown-исходник

PDF SHA-256:

```
172c38bb87dab58c2e480f9a49da490834452fb691987c9bbdcbaaee64013622
```

За основу взят именно эволюционный подход к существующему `internet-search-main`: сохраняется его control plane, TASK-модель, PostgreSQL, Redis, web UI и эксплуатационная модель, а сетевой data plane переводится на ZMap/ZGrab2. Это соответствует выводам предоставленного исследования. filecite turn0file1 Криптографическая классификация отдельно от product confirmation также следует методологии предоставленного аналитического отчёта. filecite turn0file0

Ключевая архитектура зафиксирована как:

```
Immutable provider CIDR file
        │
        ▼
ScopeCompiler
        │
        ├── normalized allowlist
        ├── mandatory denylist
        └── scope manifest + SHA-256
        │
        ▼
Scheduler
        │
        ▼
ZMap
        │
        ├── raw artifacts
```

```
        └── durable endpoint spool
        │
        ▼
Redis Streams
        │
        ▼
ZGrab2 ──── Proxy / Egress Pool
        │
        ├── TLS / X.509
        ├── HTTP
        └── SNI observations
        │
        ▼
TLS / HTTP Normalizer
        │
        ▼
Evidence + Template Engine
        │
        ▼
Result Aggregator
        │
        ├── PostgreSQL
        ├── intermediate exports
        └── realtime UI

cAdvisor → Prometheus → Grafana → UI
```

Такое разделение соответствует назначению upstream-инструментов: ZMap предоставляет CIDR allowlist/blocklist, rate control, source IP и deterministic sharding, а ZGrab2 позиционируется как последующая application-layer стадия для L4-responsive targets. [1]

Что окончательно зафиксировано в ТЗ

Masscan полностью исключён из целевой runtime-архитектуры. Также HTTPX больше не является штатным L7 collector; основной pipeline строится на ZMap + ZGrab2. ProjectDiscovery Nuclei/TLSX/HTTPX/Naabu/mapCIDR оставлены как reference, benchmark или источник архитектурных идей, а не скрытые runtime-зависимости. Nuclei, в частности, используется как ориентир для declarative YAML DSL, а не как vulnerability runtime.

CIDR остаётся первичным объектом scope. Система **не разворачивает `/16`, `/12` и другие сети в миллионы записей PostgreSQL перед сканированием**. ZMap принимает CIDR allowlist непосредственно и имеет отдельные механизмы blocklist, PPS/bandwidth control, seed/shards, source IP, metadata/status output. [2]

Для покрытия вводится ledger:

```
TASK
  ×
PORT
```

```
  ×
ZMAP SHARD
```

Поэтому система способна ответить не только «сколько результатов найдено», но и:

```
сколько targets запланировано
сколько уже отправлено
сколько shards закончено
сколько endpoints обнаружено
сколько передано в L7
сколько TLS обработано
сколько HTTP обработано
сколько classified
сколько находится в очереди
сколько завершилось ошибкой
```

Для ZGrab2 единицей наблюдения становится:

```
IP : PORT : SNI
```

Это согласуется с его native input model `IP,DOMAIN,TAG,PORT`: при одновременном наличии IP и DOMAIN соединение устанавливается к IP, тогда как DOMAIN может использоваться для TLS SNI и HTTP Host. [3]

Прокси и распределение исходящих адресов разделены на два механизма. Для ZMap используются собственные source IP/interface/scanner nodes, поскольку raw SYN discovery нельзя корректно свести к обычному HTTP CONNECT/SOCKS transport. Для stateful L7 предусмотрены `direct`, `source_ip`, `socks5`, `http_connect`. Текущий ZGrab2 уже имеет конфигурацию `local-addr`, а его processing path использует настроенные локальные адреса при создании соединений.

В ТЗ отдельно прописана защита proxy path: прокси получает только проверенный числовой `authorized IP:port`, SNI остаётся отдельным application context, a silent fallback с прокси на прямое соединение запрещён.

Криптография и универсальный движок идентификации

Сканер в спецификации не является «GlobalProtect scanner». Это **универсальная identification platform**:

```
Collector
    ↓
Normalized Observation
    ↓
Declarative Template
    ↓
Evidence
```

```
    ↓
Classification
```

Rule engine поддерживает TLS, X.509, HTTP и метаданные, включая:

```
certificate SHA-256
SPKI SHA-256
Subject / Issuer
SAN
certificate validity
key / signature algorithms
certificate chain
TLS version
cipher suite
ALPN
SNI
HTTP status
headers
body hash
bounded body match
regex
datasets
positive / negative evidence
AND / OR / NOT
score thresholds
```

Для GlobalProtect намеренно **не введён выдуманный универсальный issuer, CN, cipher или SPKI**. Palo Alto документирует использование TCP/443 для portal/gateway и SSL tunnel, однако конфигурация сертификатов может использовать разные trust models, поэтому сам сертификат не является универсальным идентификатором продукта. [4]

Именно поэтому crypto-only правило имеет жёсткую границу:

```
classification:
  product: paloalto-globalprotect
  on_match: crypto_candidate
  maximum_tier: crypto_candidate
```

HTTP confirmation вынесено в независимое правило. В документе также заложены отдельные классы:

```
unknown
candidate
crypto_candidate
probable
```

```
http_confirmed
contradicted
```

Таким образом, статья сможет отдельно измерять точность **криптографической гипотезы** и точность полного classifier, не смешивая TLS-похожесть с доказанной принадлежностью к конкретному VPN-продукту.

Realtime, Docker и эксплуатация

В спецификацию включён полноценный realtime monitoring layer:

```
cAdvisor
   ↓
Prometheus
   ↓
Grafana
   ├── Executive Scan
   ├── Pipeline
   ├── Containers
   ├── Egress
   ├── TLS Research
   ├── Database
   └── Safety
```

Prometheus официально документирует cAdvisor как источник resource/performance metrics Docker-контейнеров и показывает модель scrape cAdvisor через Prometheus. [5]

В основной UI дополнительно выводятся live cards каждого контейнера:

```
CPU
RAM / RSS
network RX/TX
block I/O
health
restart state
uptime
текущий throughput
```

TASK telemetry обновляется через SSE примерно раз в несколько секунд и содержит одновременно progress и pipeline counters.

Промежуточная выгрузка выполняется без остановки scan:

```
discovery → CSV / JSONL
tls       → CSV / JSONL
http      → CSV / JSONL
```

```
matches   → CSV / JSONL
all       → CSV / JSONL
```

Каждый export фиксирует database watermark и SHA-256, чтобы полученный файл представлял согласованный snapshot, хотя pipeline продолжает работать.

В спецификацию также включены structured JSON logs, correlation IDs, retry/DLQ, Redis Streams consumer groups, idempotency, backup/restore, health/readiness probes, Docker volumes, migration v1→v2, CI pipeline, integration laboratory и scope-leakage tests.

Отдельно сформулировано требование:

> **scope leakage = 0 network attempts outside authorized scope**

и defense-in-depth реализуется одновременно через ScopeCompiler, ZMap allowlist/blocklist, повторную pre-probe проверку, proxy destination validation, redirect/SNI guards и рекомендованный egress firewall.

Файлы для передачи разработчикам

Помимо PDF подготовлены исходные материалы ТЗ. Архив реализации **намеренно не создавался**, как было указано в запросе; вместо этого PDF содержит полный target file tree будущего проекта и конкретные content snippets.

Материал	Файл
Итоговое ТЗ	PDF
Редактируемый исходник	Markdown
Полный manifest подготовленных hand-off файлов	FILE_MANIFEST.txt
Компонентная схема	architecture-component.svg
Data-flow / backpressure / exports	architecture-dataflow.svg
Docker deployment	deployment.svg
Mermaid component source	component.mmd
Mermaid sequence source	sequence.mmd
Mermaid deployment source	deployment.mmd
Пример `.env`	.env.example
Docker Compose skeleton	docker-compose.example.yml
SQL scope migration	0003_scope_v2.sql
GlobalProtect crypto rule	crypto-only.yaml
GlobalProtect HTTP rule	http-confirmation.yaml

В самом PDF приведён значительно более полный **target repository manifest**: API routes, workers, ZMap/ZGrab adapters, proxy transport, TLS normalizer, rule engine, migrations, web modules, monitoring dashboards, scripts и unit/integration fixtures.

Готовность ТЗ к передаче CodeX

Спецификация заканчивается формальным acceptance checklist, а не общей формулировкой «сканер должен работать». В частности, разработка не считается принятой, пока не подтверждены реальные ZMap/ZGrab2 observations, idempotent recovery, live intermediate export, container telemetry, proxy handling, scope enforcement, classifier fixtures, backup/restore и Docker deployment.

В документе также дана оценка трудоёмкости: основной P0/P1 MVP разбит на отдельные deliverables — ScopeCompiler, ZMap, durable spool/Redis, ZGrab2, TLS Normalizer, Evidence Engine, proxy pool, exports, UI, monitoring, Docker hardening и CI/CD. Исследовательская calibration GlobalProtect вынесена отдельно, чтобы готовность инфраструктуры не зависела от недоказанной уникальности TLS/X.509 признаков. Этот подход соответствует методологическим выводам обоих предоставленных исследований. filecite turn0file0 filecite turn0file1

Git commit, push, tag и release publication в ТЗ прямо запрещены без отдельной команды заказчика.

---

1 2 zmap/src/zmap.1.ronn at main · zmap/zmap · GitHub
https://github.com/zmap/zmap/blob/main/src/zmap.1.ronn

3 GitHub - zmap/zgrab2: Fast Application Layer Scanner · GitHub
https://github.com/zmap/zgrab2

4 Ports Used for GlobalProtect
https://docs.paloaltonetworks.com/ngfw/administration/firewall-administration/reference-port-number-usage/ports-used-for-globalprotect

5 Monitoring Docker container metrics using cAdvisor | Prometheus
https://prometheus.io/docs/guides/cadvisor/